

MAPEO NORMATIVO DETALLADO

Cada Pregunta y su Anclaje Regulatorio, Estándar y Marco de Referencia

CIA Triad Survey Kit 2025

"Sin referencia normativa, una pregunta de encuesta es una opinión. Con referencia normativa, es un indicador."

INSTRUCCIONES DE USO

Esta tabla mapea cada pregunta del instrumento de encuesta con:

- **Pilar CIA** correspondiente
- **Normativa / estándar** de referencia específico
- **Control o artículo concreto** invocado
- **Indicador / métrica** que la pregunta operacionaliza
- **Nivel de obligatoriedad** para organizaciones españolas en 2025

Leyenda de obligatoriedad:

-  **Obligatorio** — Exigido por normativa vinculante con régimen sancionador
-  **Recomendado** — Guía oficial o estándar de referencia sin sanción directa
-  **Emergente** — Normativa en proceso de aprobación o implementación
-  **Buenas prácticas** — Sin base regulatoria directa, consenso de la industria

BLOQUE 0: PERFIL ORGANIZACIONAL

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P0.1 (Sector)	Transversal	NIS2 / LCGC	Art. 2-3 NIS2 (sectores esenciales y digitales)	Clasificación sectorial de exposición	
P0.2 (Tamaño)	Transversal	NIS2 / RGPD	Criterios PYME; Art. 17 NIS2 (medidas proporcionales)	Factor de proporcionalidad regulatoria	
P0.3 (Ámbito)	Transversal	RGPD / DORA	Art. 3 RGPD (alcance territorial); Art. 2 DORA	Aplicabilidad normativa transfronteriza	
P0.4 (NIS2)	Transversal	NIS2 / Anteproyecto LCGC	Art. 2-3 NIS2; LCGC Disposición General	Autoidentificación como operador esencial	
P0.5 (ENS)	Transversal	ENS (RD 311/2022)	Art. 2 y 40 ENS; CCN-STIC-806	Nivel de certificación ENS	 (AAPP)
P0.6 (CISO)	Transversal	NIS2 / ENS	Art. 20 NIS2 (responsabilidad órganos directivos); ENS Art. 11	Existencia de función CISO formal	 (NIS2)
P0.7 (Presupuesto)	Transversal	ENISA NIS Investments	ENISA NIS Investments 2025 (mediana 9% IT budget)	Inversión como % del presupuesto TI	

BLOQUE 1: CONFIDENCIALIDAD

1.A. Control de Acceso e Identidad

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P1.1 (Cobertura MFA)	C	NIST CSF 2.0 / ENS / NIS2	NIST CSF: PR.AA-02; ENS Anexo II Op.acc.5; NIS2 Art. 21(2)(i)	MFA Coverage Rate (%)	
P1.2 (Tipo MFA)	C	NIST SP 800-63B / FIDO Alliance	NIST SP 800-63B AAL2/AAL3; FIDO2 WebAuthn Level 2	MFA Phishing Resistance Rate	
P1.3 (ILM/IAM)	C	ISO 27001:2022 / ENS / NIST	ISO 27001 A.5.18; ENS Op.acc.4; NIST SP 800-53 AC-2	IAM Process Maturity	 (ENS/NIS2)
P1.4 (Revisión privilegios)	C	ISO 27001:2022 / ENS / DORA	ISO 27001 A.5.18; ENS Op.acc.4; DORA Art. 9(2)	Access Review Frequency	
P1.5 (PAM)	C	NIST SP 800-53 / CIS Controls	NIST 800-53 AC-2(7); CIS Control 5 (Account Management)	PAM Coverage Rate	
P1.6 (Mínimo privilegio)	C	ISO 27001:2022 / ENS / NIST	ISO 27001 A.5.15; ENS Op.acc.6; NIST 800-53 AC-6	Least Privilege Implementation Rate	 (ENS Alto)

1.B. Cifrado y Protección de Datos

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P1.7 (Cifrado reposo %)	C	RGPD / ENS / ISO 27001	RGPD Art. 32(1)(a); ENS Mp.si.2; ISO 27001 A.8.24	Encryption at Rest Coverage (%)	
P1.8 (Algoritmos cifrado)	C	NIST / ENS CCN-STIC-807	ENS CCN-STIC-807; NIST SP 800-175B; FIPS 197 (AES)	Cryptographic Algorithm Compliance Rate	 (ENS)
P1.9 (PQC)	C	NIST PQC / ENS futura	FIPS 203 (ML-KEM); FIPS 204 (ML-DSA); FIPS 205 (SLH-DSA)	PQC Migration Readiness Index	
P1.10 (DLP)	C	RGPD / ISO 27001 / ENS	RGPD Art. 25 (privacidad por diseño); ISO 27001 A.5.12; ENS Mp.info.3	DLP Coverage Rate	
P1.11 (Exfiltración)	C	RGPD / NIS2 / ISO 27001	RGPD Art. 32; NIS2 Art. 21(2)(g); ISO 27001 A.5.13	Data Exfiltration Detection Rate	

1.C. Clasificación de Información

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P1.12 (Clasificación)	C	ISO 27001:2022 / ENS	ISO 27001 A.5.12-5.13; ENS Anexo I (dimensiones)	Information Classification Coverage	 (ENS)
P1.13 (Inventario activos)	C	ISO 27001:2022 / ENS / NIS2	ISO 27001 A.5.9; ENS Op.pl.1; NIS2 Art. 21(2)(b)	Asset Inventory Completeness Rate	

1.D. Privacidad y Shadow AI

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P1.14 (Shadow AI)	C	EU AI Act / RGPD / ISO 42001	EU AI Act Art. 9; RGPD Art. 25; ISO/IEC 42001:2023	Shadow AI Inventory Coverage Rate	● (AI Act 2026)
P1.15 (Política IA Gen.)	C	EU AI Act / RGPD	EU AI Act Art. 28; RGPD Art. 5 (limitación del propósito)	AI Governance Policy Existence	●
P1.16 (Madurez C)	C	CMMI / C2M2 / ENS	CCN-STIC-817 (madurez); C2M2 MIL 0-3	Confidentiality Maturity Index	●
P1.17 (Retos C)	C	Transversal	—	Riesgo percibido por dominio	●

BLOQUE 2: INTEGRIDAD

2.A. Verificación y Monitorización

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P2.1 (FIM)	I	NIST SP 800-53 / PCI-DSS / ENS	NIST 800-53 SI-7; PCI-DSS Req. 11.5; ENS Anexo II Mp.sw.2	FIM Coverage Rate (%)	● (PCI/ENS Alto)
P2.2 (Algoritmo hash)	I	NIST SP 800-131A / ENS CCN-STIC	NIST SP 800-131A Rev.2; ENS CCN-STIC-807 (deprecación SHA-1)	Cryptographic Hash Algorithm Compliance	●
P2.3 (Parcheo crítico)	I	ENISA / NIS2 / ENS / DORA	NIS2 Art. 21(2) (b); ENS Op.exp.4; DORA Art. 9(3); CVE SLA	TMPVC — Tiempo Mediano Parcheo Vuln. Críticas	●
P2.4 (Parcheo edge)	I	CISA KEV / Verizon DBIR / ENS	CISA KEV (Known Exploited Vulnerabilities); ENS Op.exp.4	Edge Device Patch Coverage Rate	●
P2.5 (VM process)	I	ISO 27001:2022 / NIST / ENS	ISO 27001 A.8.8; NIST 800-53 RA-5; ENS Op.exp.4	VM Process Maturity Level	● (NIS2)

2.B. Cadena de Custodia y No Repudio

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P2.6 (Firma digital %)	I+Auth	eIDAS 2 / DORA / ENS	Regl. eIDAS 2 (UE 2024/1183); DORA Art. 9; ENS Dim. Autenticidad	Digital Signature Coverage Rate	● (DORA/eIDAS)
P2.7 (SIEM/Logs inmutables)	I+Traz	NIS2 / ENS / NIST	NIS2 Art. 21(2) (f); ENS Op.exp.10; NIST 800-53 AU-9	Log Integrity and Immutability Rate	●
P2.8 (Retención logs)	I+Traz	NIS2 / ENS / RGPD	NIS2 Art. 21; ENS Nivel Alto (2 años); RGPD Art. 5(1) (e)	Log Retention Compliance Rate	●
P2.9 (Forense digital)	I+Traz	ENS / CCN-STIC / ISO 27035	ENS Op.exp.7; CCN-STIC-817; ISO/IEC 27035 (Incident Management)	Digital Forensics Readiness Level	●

2.C. Cadena de Suministro

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P2.10 (Verificación SW)	I	NIST SSDF / EU CRA / NIS2	NIST SP 800-218 (SSDF); EU Cyber Resilience Act; NIS2 Art. 21(2) (d)	Software Integrity Verification Rate	● (CRA 2027)
P2.11 (SBOM)	I	EU CRA / NIST SP 800-218	EU Cyber Resilience Act Art. 13(5); NIST SP 800-218	SBOM Coverage Rate	●
P2.12 (Incidentes proveedores)	I	NIS2 / DORA / ISO 27001	NIS2 Art. 21(2) (d); DORA Art. 28; ISO 27001 A.5.19-5.22	Third-Party Incident Impact Rate	●

2.D. IA y Datos

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P2.13 (Data poisoning)	I	EU AI Act / NIST AI RMF	EU AI Act Art. 9(4); NIST AI RMF Govern 1.7; ISO 42001	AI Data Integrity Monitoring Coverage	
P2.14 (Madurez I)	I	CMMI / C2M2 / ENS	CCN-STIC-817; C2M2	Integrity Maturity Index	
P2.15 (Retos I)	I	Transversal	—	Riesgo percibido por dominio	

BLOQUE 3: DISPONIBILIDAD

3.A. Continuidad y Recuperación

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P3.1 (BCP)	A	ISO 22301 / DORA / NIS2 / ENS	ISO 22301:2019; DORA Art. 11; NIS2 Art. 21(2) (c); ENS Op.cont.1-3	BCP Existence and Test Frequency	
P3.2 (Pruebas DRP)	A	ISO 22301 / DORA / ENS	ISO 22301 §8.5; DORA Art. 11(6); ENS Op.cont.2	DRP Test Frequency and Results	 (DORA)
P3.3 (RTO)	A	ISO 22301 / DORA / ENS	ISO 22301 §6.2; DORA Art. 12(1)(a); ENS Dim. Disponibilidad	Recovery Time Objective (RTO) Defined	 (DORA)
P3.4 (RPO)	A	ISO 22301 / DORA / ENS	ISO 22301 §6.2; DORA Art. 12(1)(b); ENS Mp.info.9	Recovery Point Objective (RPO) Defined	 (DORA)
P3.5 (Backups)	A	ISO 27001:2022 / ENS / DORA	ISO 27001 A.8.13; ENS Mp.info.9; DORA Art. 12	Backup Verification Rate	
P3.6 (3-2-1 regla)	A	NIST SP 800-34 / ISO 27001	NIST SP 800-34 Rev.1; ISO 27001 A.8.13	Backup Resilience Architecture Compliance	

3.B. Gestión de Incidentes

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P3.7 (SOC/Monitorización)	A	NIS2 / DORA / ENS	NIS2 Art. 21(2) (a)(e); DORA Art. 10; ENS Op.mon.1-3	SOC Coverage Level	
P3.8 (MTTD)	A	NIST CSF 2.0 / ISO 27035 / ENS	NIST CSF DE.CM; ISO 27035-1 §6.3; ENS Op.exp.7	Mean Time to Detect (MTTD)	
P3.9 (MTTR/MTTC)	A	NIST CSF 2.0 / DORA / NIS2	NIST CSF RS.CO / RC.CO; DORA Art. 17; NIS2 Art. 23	Mean Time to Respond/Contain	 (DORA/NIS2)
P3.10 (Ransomware experiencia)	A	ENISA / INCIBE / CCN	ENISA Ransomware Report; CCN-STIC-817; INCIBE CERT	Ransomware Incident Prevalence	
P3.11 (Postura pago rescate)	A	EUROPOL / INCIBE / FBI	EUROPOL No More Ransom; INCIBE; FBI IC3 guidelines	Ransomware Non-Payment Policy	

3.C. DDoS y Alta Disponibilidad

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P3.12 (Anti-DDoS)	A	NIS2 / ENS / DORA	NIS2 Art. 21(2) (a); ENS Anexo II (disponibilidad); DORA Art. 9	DDoS Protection Coverage Rate	 (NIS2 esenciales)
P3.13 (Uptime SLA)	A	SOC 2 / ISO 27001 / DORA	SOC 2 CC Availability; ISO 27001 A.8.14; DORA Art. 8(6)	System Availability SLA Level	 (DORA)
P3.14 (Redundancia geo)	A	DORA / ISO 22301 / ENS	DORA Art. 11(5); ISO 22301 §8.4; ENS Op.cont.4	Geographic Redundancy Coverage	

3.D. IoT/OT

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P3.15 (IoT inventario)	A	NIS2 / ENS / NIST IoT	NIS2 Art. 21(2) (b); ENS Op.pl.1; NIST IR 8259	IoT/OT Inventory and Segmentation Rate	● (NIS2)
P3.16 (Madurez A)	A	CMMI / C2M2 / ENS	CCN-STIC-817; C2M2	Availability Maturity Index	●
P3.17 (Retos A)	A	Transversal	—	Riesgo percibido por dominio	●

BLOQUE 4: EXTENSIONES CIANA

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P4.1 (PKI)	Auth	eIDAS 2 / ENS / DORA	Regl. eIDAS 2 Art. 3; ENS Dim. Autenticidad; DORA Art. 9	PKI / Qualified Certificate Coverage	● (eIDAS sectores)
P4.2 (Trazabilidad sesiones)	Traz	ENS / NIS2 / DORA	ENS Dim. Trazabilidad; NIS2 Art. 21(2) (f); DORA Art. 13(7)	Privileged Session Recording Rate	● (ENS Alto)
P4.3 (eIDAS 2)	Auth	Regl. eIDAS 2 (UE 2024/1183)	eIDAS 2 Art. 5-6 (identidad digital); QES requirement	eIDAS 2 Compliance Rate	● (sectores eIDAS)

BLOQUE 5: MARCO NORMATIVO Y CUMPLIMIENTO

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P5.1 (Marcos implementados)	C+I+A	Múltiple	ISO 27001:2022 / ENS / NIST CSF 2.0 / DORA / NIS2	Framework Adoption Rate	● (según sector)
P5.2 (No conformidad)	C+I+A	ISO 27001 / ENS	ISO 27001 §9.2; ENS CCN-STIC-806 (auditoría)	Major Non-Conformity Rate	●
P5.3 (Notificación incidentes)	A	NIS2 / RGPD / DORA	NIS2 Art. 23 (24h/72h); RGPD Art. 33; DORA Art. 19	Regulatory Incident Reporting Compliance	●
P5.4 (Seguro cibernético)	C+I+A	DORA / NIS2 / sector privado	DORA Art. 2 (transferencia de riesgo); NIS2 considerando (84)	Cyber Insurance Coverage Level	● (DORA entidades)

BLOQUE 6: CULTURA Y FACTOR HUMANO

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P6.1 (Formación)	C+I+A	NIS2 / ENS / ISO 27001	NIS2 Art. 21(2) (g) y Art. 20(2); ENS Org.2; ISO 27001 A.6.3	Security Training Coverage Rate	
P6.2 (Simulacros phishing)	C	NIST SP 800-50 / ENISA	NIST SP 800-50; ENISA Awareness Guidelines	Phishing Simulation Click Rate	
P6.3 (Reporte empleados)	C+I+A	ISO 27001 / ENS / NIS2	ISO 27001 A.6.8; ENS Org.3; NIS2 Art. 20	Employee Incident Reporting Rate	
P6.4 (Cultura seguridad)	C+I+A	NIST CSF 2.0 GV / ENS	NIST CSF GV.OC; ENS Principio de seguridad como proceso	Security Culture Maturity Level	

BLOQUE 7: TECNOLOGÍA AVANZADA

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P7.1 (PQC evaluación)	C+I	NIST PQC / NSA CNSA 2.0	FIPS 203/204/205; NSA CNSA 2.0; CCN en desarrollo	Crypto Agility Index	
P7.2 (IA para seguridad)	C+I+A	NIST AI RMF / EU AI Act	NIST AI RMF; EU AI Act Art. 9; ENISA AI Cybersecurity Guidelines	AI Security Tool Adoption Level	
P7.3 (Zero Trust)	C+I+A	NIST SP 1800-35 / CISA ZTA	NIST SP 1800-35 (jun. 2025); CISA Zero Trust Maturity Model v2	Zero Trust Implementation Score	
P7.4 (ROI ciberseguridad)	C+I+A	FAIR Institute / NIST	FAIR Model (ISO/IEC 27005 compatible); NIST CSF Govern	Cyber Risk Quantification Maturity	

BLOQUE 8: VALORACIÓN GLOBAL

Pregunta	Pilar	Marco Principal	Control / Artículo	Indicador Operacionalizado	Obligatoriedad
P8.1 (Madurez global CIA)	C+I+A	CMMI / C2M2 / ENS / NIST	CCN-STIC-817; NIST CSF IMM (Implementación Maturity Model)	Índice Global de Madurez CIA (IGM-CIA)	
P8.2-P8.5 (Obstáculos / Previsiones)	C+I+A	ENISA NIS Investments / Cisco CRI	ENISA NIS Inv. 2025; Cisco CRI 2025	Barrier Index / Investment Intent	

RESUMEN EJECUTIVO DE COBERTURA NORMATIVA

Marco Normativo	Preguntas Cubiertos	Pilares CIA	Sectores Prioritarios
ENS (RD 311/2022)	P0.5, P1.1-1.13, P2.1-2.9, P3.1-3.15 + más	C + I + A + Auth + Traz	AAPP y proveedores públicos
NIS2 / LCGC	P0.4, P1.1, P2.3, P3.1-3.9, P3.12, P5.1, P5.3, P6.1	C + I + A	Sectores esenciales (12)
DORA	P3.1-3.4, P3.7, P3.9, P4.1, P5.3	A (principal) + C + I	Sector financiero
ISO 27001:2022	P1.1-1.13, P2.1-2.12, P3.1-3.6, P6.1-6.3	C + I + A	Universal
RGPD / LOPDGDD	P1.7-1.11, P1.14, P5.3	C	Universal
NIST CSF 2.0	P1.1-1.6, P2.1-2.5, P3.7-3.9, P7.3-7.4	C + I + A	Referencia global
NIST PQC (FIPS 203-205)	P1.9, P2.2, P7.1	C + I	Alta criticidad
EU AI Act	P1.14-1.15, P2.13, P7.2	C + I	IA en procesos críticos
eIDAS 2	P2.6, P4.1, P4.3	Auth + I	Transacciones electrónicas
NIST SP 1800-35 (ZTA)	P7.3	C + I + A	Entornos modernos

Mapeo Normativo CIA Triad Survey Kit v2025 · Referencias: ENS RD 311/2022, NIS2 (UE 2022/2555), DORA (UE 2022/2554), RGPD (UE 2016/679), ISO/IEC 27001:2022, NIST CSF 2.0, NIST SP 800-53 R5, NIST PQC FIPS 203/204/205, EU AI Act (UE 2024/1689), eIDAS 2 (UE 2024/1183), ISO 22301:2019